DuocUC | ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

# Cuidarte+

## Informe de seguridad y calidad en el desarrollo de software

**ISY1102 - Seguridad y calidad en el desarrollo de software**
Sección 001V

**Integrantes**
Esteban Bravo
Diego Herrera
Luis Rosales

# 1. ÍNDICE

1. Introducción ..... **¡Error! Marcador no definido.**
2. Criterios de calidad ..... 3
3. Plan de pruebas ..... 6
3.1 Estrategia de pruebas ..... 6
3.2 Tipos de prueba ..... 7
3.3 Criterios de aceptación ..... 7
3.4 Herramientas utilizadas ..... 8
4. Diseño de casos de prueba ..... 10
Caso de Prueba 1: Control de Acceso (Rol Médico) ..... 10
Caso de Prueba 2: Rendimiento y Auditoría (Subida de Documentos) ..... 11
Caso de Prueba 3: Usabilidad (Visualización para Pacientes Adultos Mayores) ..... 12
Caso de Prueba 4: Seguridad (Cierre de Sesión y Revocación de Token) ..... 13
Caso de Prueba 5: Seguridad (Protección contra Inyección SQL en Formulario) ..... 14

# 2. Criterios de calidad

## USABILIDAD

El sistema debe ser fácil de utilizar, especialmente para adultos mayores. Para ello se establecen los siguientes criterios:

- Interfaces con tipografía legible y contraste adecuado.
- Controles de tamaño suficiente para facilitar la interacción.
- Flujos claros para registro, consulta de exámenes y documentos.
- Mensajes de error amigables y ayuda contextual.
- Navegación accesible mediante teclado y etiquetas ARIA.
- Compatibilidad con dispositivos móviles, tablets y escritorio.
- Validación mediante pruebas con usuarios, incluyendo adultos mayores.

## RENDIMIENTO

El sistema debe responder de forma rápida y soportar múltiples usuarios concurrentes:

- Operaciones CRUD simples con tiempos de respuesta menores a **300 ms** bajo carga normal.
- La página principal debe cargar en menos de **2 segundos** en una conexión móvil promedio.
- Debe soportar por defecto **200 usuarios concurrentes**.
- La subida y descarga de documentos debe completarse en un tiempo no superior a **10 segundos**.

## ESTABILIDAD

- Disponibilidad objetivo de **99,5% mensual**.
- Actualizaciones mediante ventanas de mantenimiento controladas.
- Migraciones de datos seguras.
- Políticas de respaldo y recuperación para evitar pérdidas de información.

## CONFIABILIDAD

La confiabilidad se aborda principalmente mediante requisitos de seguridad y disponibilidad:

- Uso obligatorio de **TLS** en las comunicaciones.
- Contraseñas protegidas con **bcrypt**.
- Encriptación de datos sensibles.
- Control de acceso basado en roles.
- Protección contra ataques CSRF, XSS y SQL Injection.
- Registro de auditoría para acciones críticas.
- Pruebas de penetración sin hallazgos críticos como criterio de aceptación.

## MANTENIBILIDAD

- Arquitectura multicapa separada en Frontend (React), Backend (Express) y Base de Datos (PostgreSQL).
- API RESTful para desacoplar componentes.
- Actualizaciones planificadas mediante ventanas de mantenimiento.
- Uso de auditorías, respaldos y documentación de endpoints mediante Swagger.
    - Arquitectura multicapa separada en Frontend (React), Backend (Express) y Base de Datos (PostgreSQL).
    - API RESTful para desacoplar componentes.
    - Actualizaciones planificadas mediante ventanas de mantenimiento.
    - Uso de auditorías, respaldos y documentación de endpoints mediante Swagger.

## PROTECCIÓN DE DATOS

El sistema debe resguardar la información médica y personal de los pacientes mediante:

- Uso obligatorio de **TLS** en todas las comunicaciones entre cliente y servidor para proteger los datos en tránsito.
- **Encriptación de datos sensibles en reposo**, evitando accesos no autorizados a la información almacenada.
- **Hashing seguro de contraseñas mediante bcrypt**, impidiendo almacenar contraseñas en texto plano.
- Cumplimiento de las **normativas de protección de datos personales** aplicables a la información clínica.
- Políticas de **respaldo y recuperación** para prevenir pérdida de información.

## CONTROL DE ACCESO

El acceso al sistema está basado en autenticación y roles:

- Los usuarios deben autenticarse mediante **nombre de usuario y contraseña**.
- El manejo de sesión se realiza mediante **JWT (JSON Web Token)**.
- Existe **control de acceso por roles** en el backend.
- Las reglas de negocio establecen permisos diferenciados:

    1. Paciente: solo lectura de su información. Médico: acceso a la información clínica y gestión de exámenes.
    2. Administrador: acceso completo a operaciones de creación, lectura, actualización y eliminación. El sistema debe permitir cierre de sesión y revocación de tokens.

## MANEJO DE ERRORES

- Validación de todas las entradas en el servidor (**server-side validation**) para los endpoints.
- Protección contra ataques **CSRF, XSS y SQL Injection** mediante validación y saneamiento de datos.
- Mensajes de error amigables y ayuda contextual como parte de los requisitos de usabilidad.

## INTEGRIDAD DE LA INFORMACIÓN

- Registro de auditoría para acciones críticas como creación, edición y eliminación de registros, además de la subida y descarga de documentos.
- Validación de datos durante las operaciones CRUD.
- Almacenamiento controlado de documentos médicos en un repositorio interno con referencia en la base de datos.
- Respaldo y recuperación de datos para evitar pérdidas de información.
- Autenticación, autorización y trazabilidad de acciones mediante auditoría y control de roles.

## NORMATIVAS Y LEYES

- El sistema debe **garantizar el cumplimiento de la normativa de protección de datos personales**, debido a que almacena y procesa información clínica sensible de pacientes.
- Dentro de los requisitos de seguridad se especifica el **cumplimiento de normativas de protección de datos personales** como requisito obligatorio.

## ESTÁNDARES TÉCNICOS

- Uso obligatorio de **TLS (Transport Layer Security)** para proteger todas las comunicaciones entre cliente y servidor.
- Contraseñas almacenadas mediante **hashing seguro (bcrypt)**.
- Implementación de **JWT (JSON Web Token)** para la gestión de sesiones y autenticación.
- Protección contra vulnerabilidades comunes como **CSRF, XSS y SQL Injection**.
- Arquitectura tecnológica definida con **React** para Frontend, **Express/Node.js** para Backend y **PostgreSQL** como base de datos.
- Compatibilidad con las últimas versiones de Chrome, Firefox, Safari y Edge
- API basada en estándares **RESTful JSON** para la comunicación entre componentes.

## POLÍTICAS INTERNAS

- Política de contraseñas con un mínimo configurable de 12 caracteres, incluyendo mayúsculas, minúsculas, números y símbolos.
- Control de acceso basado en roles (Administrador, Médico y Paciente).
- Registro obligatorio de auditoría para acciones críticas como creación, modificación y eliminación de información, además de la carga o descarga de documentos.
- Políticas de respaldo y recuperación de datos para garantizar la continuidad del servicio.
- Almacenamiento controlado de documentos médicos debido a la sensibilidad de la información que contienen.
- Disponibilidad objetivo del sistema de **99,5% mensual** y actualizaciones mediante ventanas de mantenimiento controladas.

# 3. Plan de pruebas

## 3.1 Estrategia de pruebas

La ejecución del plan de pruebas se llevará a cabo con un enfoque mixto. Las **pruebas manuales** permitirán validar la experiencia de usuario, accesibilidad y cumplimiento de los flujos de negocio, mientras que las **pruebas automatizadas** ayudarán a verificar de manera continua las funcionalidades críticas como autenticación, gestión de pacientes, exámenes médicos, seguridad y APIs.

Las **etapas de plan de pruebas** serán las siguientes:

1. Planificación
2. Diseño de casos de prueba
3. Preparación del entorno
4. Ejecución de pruebas
5. Registro y seguimiento de defectos
6. Cierre de pruebas.

**Priorización de pruebas**

- **Prioridad Alta**
  - Autenticación y gestión de sesión.
  - Control de acceso por roles.
  - Gestión de pacientes.
  - Gestión de exámenes médicos.
  - Protección de datos y auditoría.
- **Prioridad Media**
  - Carga y descarga de documentos.
  - Compatibilidad entre navegadores.
  - Integración entre módulos.
- **Prioridad Baja**
  - Aspectos visuales menores.
  - Mejoras de experiencia de usuario no críticas.

**Criterios de entrada**

Las pruebas podrán comenzar cuando:

- Los requisitos estén aprobados.
- El ambiente de pruebas esté disponible.
- Los módulos a evaluar estén desarrollados.
- Se disponga de datos de prueba y usuarios para cada rol.
- Los casos de prueba hayan sido definidos y revisados.

**Criterios de salida**

Las pruebas finalizarán cuando:

- Se hayan ejecutado todos los casos de prueba planificados.
- Los defectos críticos y altos estén corregidos y validados.
- Se cumplan los criterios de aceptación definidos para funcionalidad, seguridad, rendimiento y usabilidad.
- Se emita el informe final con los resultados obtenidos y la aprobación para la liberación del sistema.

## 3.2 Tipos de prueba

Para el sistema Cuidarte+ se realizarán pruebas:

- **Funcionales**
- **No funcionales**
- **De seguridad**
- **Integración**
- **Usabilidad**
- **Rendimiento.**

Estas pruebas permitirán verificar el correcto funcionamiento de las funcionalidades del sistema, la protección de la información clínica, la interacción entre módulos, la facilidad de uso para los usuarios, especialmente adultos mayores, y el cumplimiento de los requisitos de rendimiento, disponibilidad y calidad definidos para la plataforma.

## 3.3 Criterios de aceptación

**1. Pruebas Funcionales**

- El 100% de los casos de prueba críticos son ejecutados exitosamente.
- Las funcionalidades cumplen con los requisitos definidos.
- Las operaciones CRUD (crear, consultar, modificar y eliminar) funcionan correctamente.
- No existen defectos críticos o altos abiertos al finalizar las pruebas.
- Los resultados obtenidos coinciden con los resultados esperados.

**2. Pruebas No Funcionales**

- El sistema es accesible desde computadores, tablets y dispositivos móviles.
- La aplicación funciona correctamente en los navegadores definidos (Chrome, Firefox, Edge y Safari).
- La disponibilidad del sistema cumple el objetivo de 99,5%.
- No se presentan fallos que afecten la operación normal del servicio.

**3. Pruebas de Seguridad**

- Solo usuarios autenticados pueden acceder al sistema.
- Cada usuario accede únicamente a las funcionalidades permitidas por su rol.
- Los datos viajan mediante conexiones seguras (TLS/HTTPS).
- No se detectan vulnerabilidades críticas o altas.
- Las pruebas de SQL Injection, XSS y CSRF son rechazadas correctamente.
- Todas las acciones críticas quedan registradas en auditoría.

**4. Pruebas de Integración**

- Los módulos intercambian información correctamente.
- Los datos guardados en una funcionalidad son visibles en los módulos relacionados.
- No existen pérdidas ni inconsistencias de información durante la comunicación entre componentes.
- La integración entre Frontend, Backend y Base de Datos funciona sin errores.

**5. Pruebas de Usabilidad**

- Los usuarios pueden completar las tareas principales sin asistencia técnica.
- La navegación es clara e intuitiva.
- Los mensajes de validación y error son comprensibles.
- Los textos poseen tamaño y contraste adecuados.
- El sistema puede ser utilizado satisfactoriamente por adultos mayores durante las pruebas de usuario.

**6. Pruebas de Rendimiento**

- Las operaciones CRUD responden en menos de 300 ms bajo condiciones normales.
- La página principal carga en menos de 2 segundos.
- El sistema soporta al menos 200 usuarios concurrentes.
- La carga y descarga de documentos se realiza en menos de 10 segundos.
- No se producen errores, bloqueos ni degradación significativa del servicio bajo carga.

## 3.4 Herramientas utilizadas

### 3.4.1 Recursos humanos (roles involucrados)

- **Tester / Analista QA:** Diseña, ejecuta y documenta los casos de prueba.
- **Desarrolladores:** Apoyan en la corrección de defectos y validación de soluciones.
- **Analistas de Seguridad:** Ejecutan pruebas de seguridad y validan controles de protección de datos.
- **Médicos:** Participan en la validación funcional de los procesos clínicos.
- **Pacientes:** Participan en pruebas de usabilidad y validación de consulta de información.
- **Administradores:** Validan funcionalidades de administración, auditoría y gestión de usuarios.
- **Stakeholders del proyecto:** Revisan los resultados y validan la aceptación final del sistema.

### 3.4.2 Recursos técnicos

| Herramienta | Propósito |
|---|---|
| **Postman** | Pruebas funcionales y de integración sobre APIs REST. |
| **JMeter** | Pruebas de rendimiento, carga y concurrencia. |
| **Selenium** | Automatización de pruebas funcionales y regresión. |
| **OWASP ZAP** | Detección de vulnerabilidades y pruebas de seguridad. |
| **Jira** | Gestión de incidencias, defectos y seguimiento de pruebas. |
| **Lighthouse** | Evaluación de rendimiento, accesibilidad y buenas prácticas. |
| **WAVE** | Validación de accesibilidad web. |

**Equipos**

- Computadores de escritorio para ejecución de pruebas.
- Tablets para validación de compatibilidad y usabilidad.
- Dispositivos móviles Android e iOS.
- Servidor de pruebas o máquina virtual para despliegue del sistema.

**Navegadores**

- Google Chrome (última versión estable).
- Mozilla Firefox (última versión estable).
- Microsoft Edge (última versión estable).
- Safari (última versión estable disponible).

**Tecnologías del sistema a validar**

- Frontend: **React**
- Backend: **Node.js / Express**
- Base de Datos: **PostgreSQL**
- API RESTful en formato JSON.
- Autenticación mediante JWT.
- Comunicación segura mediante HTTPS/TLS.

### 3.4.3 Entorno de pruebas

Se recomienda disponer de los siguientes ambientes:

**Ambiente de Desarrollo (DEV)**

- Utilizado por los desarrolladores para implementar nuevas funcionalidades y corregir defectos.
- Permite realizar pruebas unitarias y validaciones preliminares.

**Ambiente de Calidad (QA)**

- Replica las condiciones de producción de manera controlada.
- Utilizado para ejecutar pruebas funcionales, integración, seguridad, rendimiento y usabilidad.
- Contiene datos de prueba ficticios y configuraciones similares al entorno real.

**Ambiente de Preproducción (UAT o Staging)**

- Ambiente utilizado para validación final por parte de los usuarios del negocio.
- Permite verificar que los requisitos y criterios de aceptación se cumplen antes de la liberación.

**Ambiente de Producción**

- Entorno operacional utilizado por los usuarios finales.
- No se ejecutarán pruebas invasivas o de carga en este ambiente, salvo validaciones controladas posteriores a la liberación.

# 4. Diseño de casos de prueba

## Caso de Prueba 1: Control de Acceso (Rol Médico)

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-01** | Autenticación y acceso a gestión de exámenes por rol Médico | Sección 2 - Criterios de calidad: Control de Acceso / Políticas Internas |
| **DESCRIPCIÓN** | | |
| Verificar que un usuario con el rol de "Médico" pueda iniciar sesión mediante autenticación y acceder correctamente a la gestión de exámenes médicos. | | |
| **PRECONDICIONES** | | |
| El sistema debe estar en ejecución en el ambiente de Q.A. Debe existir un usuario en la base de datos con el rol asignado de "Médico". | | |
| **PASOS** | | |
| 1. Ingresar a la página principal de login de Cuidarte+.<br>2. Ingresar el nombre de usuario y contraseña del médico.<br>3. Hacer clic en "Iniciar sesión".<br>4. Navegar a la sección de "Gestión de exámenes". | | |
| **RESULTADO ESPERADO** | | |
| El sistema valida las credenciales y maneja la sesión mediante JWT (JSON Web Token). El usuario es redirigido a su panel, mostrando el acceso a la información clínica y gestión de exámenes. | | |
| **CRITERIO DE ACEPTACIÓN** | | |
| Solo usuarios autenticados pueden acceder al sistema. Cada usuario accede únicamente a las funcionalidades permitidas por su rol. | | |
| **DATOS DE PRUEBA** | | |
| **Usuario**: `medico_perez`<br>**Contraseña**: `MedPerez2024*` (cumpliendo política de mínimo 12 caracteres, mayúsculas, minúsculas, números y símbolos). | | |

## Caso de Prueba 2: Rendimiento y Auditoría (Subida de Documentos)

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-02** | Carga de documento médico y registro de auditoría | Sección 2 - Criterios de calidad: Rendimiento / Integridad de la Información |

**DESCRIPCIÓN**

Validar que la subida de un documento clínico al repositorio interno tarde un tiempo aceptable y que esta acción quede debidamente registrada en la bitácora.

**PRECONDICIONES**

El usuario (Médico o Administrador) debe estar autenticado en el sistema. Se debe contar con un archivo de prueba en el equipo.

**PASOS**

1. Ingresar al perfil de un paciente específico.

2. Seleccionar la opción para adjuntar documento.

3. Cargar el archivo de prueba desde el equipo local.

4. Hacer clic en "Guardar" y cronometrar el tiempo de respuesta.

5. Revisar el registro de auditoría en la base de datos.

**RESULTADO ESPERADO**

El documento se almacena de forma controlada en el repositorio interno. El sistema arroja un mensaje de éxito rápido y se genera un registro automático en la auditoría indicando qué usuario realizó la carga.

**CRITERIO DE ACEPTACIÓN**

La carga y descarga de documentos se realiza en un tiempo no superior a 10 segundos. Todas las acciones críticas quedan registradas en auditoría.

**DATOS DE PRUEBA**

Archivo: `resultado_resonancia.pdf`

Paciente ID: PAC-8472

## Caso de Prueba 3: Usabilidad (Visualización para Pacientes Adultos Mayores)

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-03** | Validación de interfaces legibles y navegación para pacientes | Sección 2 - Criterios de calidad: Usabilidad |
| **DESCRIPCIÓN** | | |
| Verificar que un paciente (especialmente un usuario adulto mayor) pueda navegar por el sistema de forma fácil, con flujos claros para visualizar su información. | | |
| **PRECONDICIONES** | | |
| El sistema debe estar desplegado en el ambiente de pruebas. El tester o usuario paciente debe acceder desde una tablet o dispositivo móvil. | | |
| **PASOS** | | |
| 1. Iniciar sesión con una cuenta que tenga el rol "Paciente".<br><br>2. Navegar al menú de "Consulta de exámenes".<br><br>3. Inspeccionar el tamaño de los controles de interacción y botones.<br><br>4. Leer la información clínica desplegada en pantalla. | | |
| **RESULTADO ESPERADO** | | |
| El sistema despliega la información utilizando tipografía legible y un contraste adecuado de colores. Los controles tienen un tamaño suficiente para facilitar la interacción de un adulto mayor. | | |
| **CRITERIO DE ACEPTACIÓN** | | |
| Los usuarios pueden completar las tareas principales (como leer su información) sin asistencia técnica. El sistema puede ser utilizado satisfactoriamente por adultos mayores. | | |
| **DATOS DE PRUEBA** | | |
| **Dispositivo**: Tablet iPad o Android.<br><br>**Rol**: Paciente (Solo lectura de su información). | | |

## Caso de Prueba 4: Seguridad (Cierre de Sesión y Revocación de Token)

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-04** | Cierre de sesión y revocación del token de autenticación (JWT) | Sección 2 - Criterios de calidad: Control de Acceso / Estándares Técnicos |
| **DESCRIPCIÓN** | | |
| Verificar que al presionar "Cerrar sesión" el token JWT sea invalidado correctamente, impidiendo que el usuario vuelva a ingresar utilizando el botón "Atrás" del navegador. | | |
| **PRECONDICIONES** | | |
| El usuario (cualquier rol) debe tener una sesión activa iniciada en el sistema. | | |
| **PASOS** | | |
| 1. Iniciar sesión en Cuidarte+ con credenciales válidas.<br><br>2. Navegar al menú del perfil de usuario.<br><br>3. Hacer clic en la opción "Cerrar sesión".<br><br>4. Intentar presionar el botón "Atrás" (Back) en la barra de navegación del navegador web. | | |
| **RESULTADO ESPERADO** | | |
| El sistema finaliza la sesión, elimina/revoca el token JWT y redirige de inmediato a la pantalla de login. Al presionar "Atrás", el navegador no muestra la pantalla anterior y exige iniciar sesión de nuevo. | | |
| **CRITERIO DE ACEPTACIÓN** | | |
| El sistema debe permitir el cierre de sesión y la revocación de tokens. Solo usuarios autenticados pueden acceder al sistema. | | |
| **DATOS DE PRUEBA** | | |
| **Usuario: medico_perez**<br><br>**Navegador: Google Chrome / Mozilla Firefox** | | |

## Caso de Prueba 5: Seguridad (Protección contra Inyección SQL en Formulario)

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-05** | Validación de saneamiento de datos y prevención de SQL Injection en búsqueda de pacientes | Sección 2 - Criterios de calidad: Manejo de Errores / Estándares Técnicos |

**DESCRIPCIÓN**

Verificar que los campos de búsqueda e ingreso de datos en la plataforma validen y saneen las entradas en el servidor, bloqueando intentos de inyección SQL y mostrando mensajes de error amigables sin exponer información sensible de la base de datos.

**PRECONDICIONES**

El sistema debe estar desplegado en el ambiente de QA. El usuario (Médico o Administrador) debe estar autenticado en el sistema.

**PASOS**

1. Iniciar sesión con un usuario con rol "Médico" o "Administrador".

2. Navegar al módulo de "Gestión de Pacientes" o "Consulta de Exámenes".

3. Ingresar en el campo de búsqueda de RUT/Nombre la siguiente cadena maliciosa: `' OR '1'='1`.

4. Hacer clic en el botón "Buscar".

5. Inspeccionar el comportamiento del sistema y la respuesta HTTP.

**RESULTADO ESPERADO**

El servidor valida y sanitiza la entrada (server-side validation). La consulta maliciosa es rechazada, no se devuelven registros no autorizados ni se generan excepciones SQL en pantalla, desplegando únicamente un mensaje amigable al usuario.

**CRITERIO DE ACEPTACIÓN**

Las pruebas de SQL Injection, XSS y CSRF son rechazadas correctamente. No se detectan vulnerabilidades críticas o altas.

**DATOS DE PRUEBA**

**Campo de Búsqueda:** `' OR '1'='1 --`

**Rol: Médico / Administrador**